Lab 16 — Linux Hardening Baseline with Lynis

> **SY0-701 Objective 2.5** — Explain the purpose of mitigation techniques used to secure the enterprise
>
> **Domain 2** — Threats, Vulnerabilities, and Mitigations (22%) · **Time:** ~55 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

Goal: audit a Linux host, apply a set of CIS-aligned mitigations, then re-audit to measure a quantified improvement in the hardening index.

You'll build: a before/after hardening score with the baseline fixes (SSH, sysctl, banner, auto-updates) applied.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; tools installed in step 1.

Background

- **Hardening** reduces the attack surface by removing unnecessary exposure: patching, encryption, disabling ports/protocols, changing defaults and adding host-based controls.
- **Configuration enforcement** keeps every host at an approved secure **baseline**; a benchmark such as CIS or a DISA STIG defines that baseline.
- **Least privilege** and a directive **login banner** are mitigation techniques named in objective 2.5.
- **Lynis** audits a host against hundreds of checks and reports a 0-100 *hardening index* plus prioritised suggestions.
- Quantifying the score before and after proves the mitigations worked — the heart of configuration management.

Steps

1. Install Lynis and automatic updates

```
apt-get update -qq && apt-get install -y lynis unattended-upgrades
lynis --version
```

2. Run the initial audit and note the score

Record the starting hardening index (often 60-70 on a stock cloud image).

```
lynis audit system --quick 2>/dev/null | tee lynis-before.txt >/dev/null
grep -i 'hardening index' lynis-before.txt
```

3. Disable unused services

Every unused listening service is attack surface; turn off the ones not needed on a server.

```
systemctl disable --now avahi-daemon cups 2>/dev/null
true   # ignore "not found" on minimal images
```

4. Harden the SSH configuration

Disable root login, disable X11 forwarding and reload the daemon.

```
sed -i 's/^#*PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
sed -i 's/^#*X11Forwarding.*/X11Forwarding no/' /etc/ssh/sshd_config
systemctl reload ssh 2>/dev/null || service ssh reload 2>/dev/null || true
```

5. Set a directive login banner

A warning banner is a *directive* control — it instructs users of the terms of use.

```
printf 'WARNING: Authorised use only. All activity is logged.\n' > /etc/issue.net
sed -i 's|^#*Banner.*|Banner /etc/issue.net|' /etc/ssh/sshd_config
systemctl reload ssh 2>/dev/null || true
```

6. Apply kernel sysctl hardening

Tighten kernel exposure and enable reverse-path filtering.

```
cat > /etc/sysctl.d/99-hardening.conf <<'EOF'
kernel.dmesg_restrict=1
kernel.kptr_restrict=2
net.ipv4.conf.all.rp_filter=1
net.ipv4.conf.all.accept_redirects=0
net.ipv4.icmp_echo_ignore_broadcasts=1
EOF
sysctl --system >/dev/null
```

7. Enable automatic security updates

Prompt patching is the single highest-impact mitigation; enable it non-interactively.

```
dpkg-reconfigure -f noninteractive unattended-upgrades
```

8. Re-audit and compare the hardening index

```
lynis audit system --quick 2>/dev/null | tee lynis-after.txt >/dev/null
grep -i 'hardening index' lynis-before.txt lynis-after.txt
```

```
lynis-before.txt:  Hardening index : 63 [#############        ]
lynis-after.txt:   Hardening index : 76 [################     ]
```

Test it

Confirm the mitigations are in place and the score improved.

```
grep -q 'PermitRootLogin no' /etc/ssh/sshd_config && echo "SSH HARDENED"
test -f /etc/sysctl.d/99-hardening.conf && echo "SYSCTL BASELINE APPLIED"
B=$(grep -i 'hardening index' lynis-before.txt | grep -oE '[0-9]+' | head -1)
A=$(grep -i 'hardening index' lynis-after.txt  | grep -oE '[0-9]+' | head -1)
echo "before=$B after=$A"; [ "${A:-0}" -gt "${B:-0}" ] && echo "SCORE IMPROVED"
```

Expected: SSH and sysctl mitigations are present, and the after score is higher than the before score (typically 10-15 points).

Troubleshooting

Symptom	Fix
Score does not move	Lynis caches some results; run the full `lynis audit system` without `--quick`.
`systemctl reload ssh` fails	The unit may be `sshd` or `ssh`; try both, or `service ssh reload`.
`unattended-upgrades` prompt	The `-f noninteractive` flag suppresses it; ensure `DEBIAN_FRONTEND=noninteractive` if it still prompts.

Challenge

Pick two Lynis suggestions from `lynis-after.txt`, map each to its CIS Benchmark control number, remediate them, and show the score rise again. Then explain the difference between *configuration enforcement* and a one-time fix.

Reflection

Objective 2.5 lists hardening, least privilege and configuration enforcement. Why is a quantified before/after score more useful to management than a checklist of "done" items?

Exam tips

- Hardening = patch, encrypt, remove software, disable ports/protocols, change defaults, add host firewall/HIPS.
- A login banner is a *directive* control; disabling root SSH is *preventive*.
- Configuration enforcement keeps hosts on the baseline and flags drift automatically.
- CIS Benchmarks and DISA STIGs are the authoritative baselines the exam references.

References

- CIS Benchmarks — https://www.cisecurity.org/cis-benchmarks
- DISA STIGs — https://public.cyber.mil/stigs/
- Lynis documentation — https://cisofy.com/documentation/lynis/
- NIST SP 800-123 Server Security — https://csrc.nist.gov/pubs/sp/800/123/final

---